

UNIVERSIDAD NACIONAL DE COLOMBIA

Sede Bogotá — Facultad de Ingeniería

Asignatura: Ciberseguridad II

Análisis Forense Básico en Sistemas Windows mediante Herramientas Sysinternals

Docente: José Javier Moreno Corredor

Estudiante: Miguel Angel Rodriguez Bohorquez

Fecha de entrega: 7 de mayo de 2026

6.2 Introducción

El presente informe técnico documenta el proceso de análisis forense básico realizado sobre una máquina virtual con sistema operativo Windows 10, previamente comprometida en un entorno de laboratorio controlado. El implante analizado corresponde a un agente generado mediante el framework Sliver, desplegado a través de un loader cuyo comportamiento observado es compatible con el uso de indirect syscalls y ejecución reflectiva en memoria.

A pesar de la sofisticación técnica del implante, el análisis demuestra que la correlación de indicadores de comportamiento observable mediante herramientas de la suite Sysinternals y Sysmon permite identificar evidencias forenses suficientes para determinar la naturaleza del incidente. El objetivo principal del ejercicio no es describir el ataque ejecutado, sino efectuar un análisis técnico posterior que permita identificar rastros, evidencias y comportamientos anómalos presentes en el sistema, actuando desde la perspectiva del equipo de defensa (Blue Team).

6.3 Descripción del Entorno

Parámetro	Detalle
Sistema operativo	Windows 10 (64 bits)
Nombre del equipo	DESKTOP-FL3HVDT
Usuario analizado	UNAL CYBEROPS 2
Dirección IP (víctima)	40.0.0.2
Dirección IP (servidor C2)	20.0.0.2
Herramientas de análisis	Sysinternals Suite + Sysmon v15 (configuración SwiftOnSecurity)
Entorno de laboratorio	Máquina virtual VMware — red aislada, uso exclusivamente académico
Naturaleza del payload	Ejecución en memoria sin evidencia de escritura adicional en disco durante el periodo analizado
Framework del implante	Sliver C2 — modo beacon

6.4 Herramientas Utilizadas

Para el desarrollo del análisis se seleccionaron siete herramientas de la suite Sysinternals, cada una elegida por su pertinencia para una dimensión específica del comportamiento del implante:

Herramienta	Función en el análisis	Justificación de selección
Process Explorer	Análisis de procesos activos, hilos, tiempos de CPU y actividad de red/disco.	Permite identificar anomalías en el comportamiento del proceso: consumo de Kernel

Herramienta	Función en el análisis	Justificación de selección
		Time, hilos compatibles con beacon interval y footprint de memoria desproporcionado.
TCPView	Identificación de conexiones TCP/UDP activas y procesos asociados.	Herramienta directa para identificar comunicación activa con el servidor C2 en el momento del análisis.
Sysmon	Registro persistente de eventos: creación de procesos, conexiones de red, modificaciones de registro.	Proporciona telemetría forense con timestamps precisos y hashes criptográficos; fundamental para reconstruir la línea de tiempo del incidente.
Sigcheck	Verificación de firma digital, análisis de entropía y metadatos del PE.	Permite caracterizar el ejecutable mediante la ausencia de firma, entropía elevada y metadatos vacíos.
ListDLLs	Enumeración de bibliotecas cargadas en memoria, filtradas por firma digital.	Su resultado es significativo tanto si detecta DLLs maliciosas como si confirma su ausencia, lo cual es coherente con técnicas que minimizan la carga de módulos adicionales.
VMMMap	Análisis del mapa de memoria virtual: tipo, tamaño y protección de cada región.	Herramienta clave para identificar regiones ejecutables sin respaldo en disco, consecuencia directa de la carga reflectiva del payload.
Autoruns	Verificación de mecanismos de persistencia en ubicaciones de arranque del sistema.	Permite documentar la presencia o ausencia de persistencia activa, aspecto exigido explícitamente en el alcance de la actividad.

6.5 Procedimiento

El análisis se estructuró en cinco fases secuenciales, siguiendo una lógica que avanza desde la identificación del proceso sospechoso hasta la verificación de persistencia. Sysmon fue instalado y configurado previamente al inicio de la ejecución del loader, garantizando la captura de todos los eventos relevantes desde el comienzo del incidente.

Fase 1 — Configuración del entorno de monitoreo

Se instaló Sysmon como servicio del sistema mediante el comando `sysmon.exe -accepteula -i sysmonconfig.xml`, aplicando el perfil de configuración de SwiftOnSecurity. Se verificó el estado del servicio con `sc query sysmon`. Se abrió el Visor de eventos apuntando a Applications and Services Logs → Microsoft → Windows → Sysmon → Operational para monitorear los eventos en tiempo real.

Fase 2 — Identificación del proceso sospechoso

Se ejecutó Process Explorer con privilegios de administrador y se activó la verificación de firmas digitales (Options → Verify Image Signatures). Se ejecutó el loader en la máquina virtual y se localizó el proceso loader (5).exe en el árbol de procesos. Se examinaron las pestañas Performance, Threads y Disk and Network para registrar métricas de comportamiento. Se anotó el PID asignado (4312) para su uso en las fases siguientes.

Fase 3 — Análisis de red

Se utilizó TCPView para identificar conexiones activas y se exportó su estado en el momento del análisis. Paralelamente, se filtraron los eventos Sysmon ID 3 para obtener metadatos adicionales: IP origen y destino, puerto, protocolo y timestamp exacto de cada conexión generada por el proceso.

Fase 4 — Análisis del ejecutable y memoria

Se ejecutó Sigcheck con los parámetros -accepteula -a -h sobre el archivo loader (5).exe para obtener metadatos del PE, valor de entropía y hashes criptográficos. Se ejecutó ListDLLs con el parámetro -u -accepteula sobre el PID 4312 para identificar módulos sin firma digital. Se utilizó VMMap seleccionando el proceso por PID, examinando el mapa completo de regiones de memoria con especial atención a regiones ejecutables sin módulo asociado.

Fase 5 — Verificación de persistencia

Se ejecutó Autoruns con privilegios de administrador, activando el filtro Options → Hide Microsoft Entries. Se utilizó el campo de búsqueda con el término 'loader' para filtrar directamente cualquier entrada relacionada con el ejecutable analizado. Se revisaron todas las pestañas disponibles: Logon, Scheduled Tasks, Services, Drivers, WMI, Applnit, Boot Execute e Image Hijacks.

6.6 Hallazgos

Hallazgo 1 — Process Explorer: comportamiento anómalo del proceso (PID 4312)

Indicador	Valor observado	Significancia forense
Kernel Time vs User Time	19.250 s kernel / 5.796 s usuario	Actividad desproporcionada en espacio del kernel; indicador compatible con llamadas directas al sistema
Virtual Size	5,589,688 KB (~5.3 GB)	Espacio virtual desproporcionado respecto a la función declarada del ejecutable
Hilo TID 1916 — Start Address	loader (5).exe+0x1440	Hilo iniciado desde una dirección interna del ejecutable sin nombre de función exportada; compatible con ejecución de código cargado en memoria
Disk Writes durante el periodo analizado	0 B escritos en disco	Sin evidencia de escritura adicional al disco durante el periodo analizado
Actividad de red	Receive Bytes activos, Send Bytes activos	Comunicación de red activa en el momento del análisis
Proceso padre	explorer.exe	El loader fue ejecutado manualmente por el usuario desde el escritorio

Hallazgo 2 — TCPView: conexiones activas hacia el servidor C2

Campo	Valor	Significancia forense
Estado	Established (dos conexiones)	Dos canales de comunicación activos simultáneamente en el momento del análisis
Proceso origen	loader (5).exe — PID 4312	El proceso identificado en Process Explorer origina ambas conexiones
IP de destino	20.0.0.2	Dirección IP del servidor de comando y control
Puerto de destino	https (443)	Uso del puerto estándar HTTPS; dificulta la diferenciación frente a tráfico legítimo en inspecciones superficiales
Puertos locales observados	51007 y 51006	Dos puertos efímeros activos; indica múltiples canales C2 simultáneos o modo session

Hallazgo 3 — Sysmon: telemetría persistente del incidente

Event ID	Timestamp (UTC)	Hallazgo	Significancia
ID 1 — Process Create	15:39:23.805	PID 4312. FileVersion, Description, Company, Product y OriginalFileName: todos vacíos ('-'). SHA256: 634A6640D6F2D122... ParentImage: C:\Windows\explorer.exe	Binario sin metadatos válidos ejecutado manualmente; indicador de ejecutable no legítimo
ID 13 — Registry	15:39:25.528	svchost.exe escribe en InventoryApplicationFile. TargetObject incluye 'loader (5).exe'. Details: (Empty) en campo Publisher.	Publisher vacío corrobora ausencia de firma; fuente de telemetría independiente del análisis
ID 3 — Network	15:39:28.631	TCP hacia 20.0.0.2:443, puerto local 50639. DestinationHostname: -. Image: loader (5).exe	Conexión al C2 confirmada por Sysmon con metadatos completos; DestinationHostname vacío indica destino sin DNS

Hallazgo 4 — Sigcheck: análisis del ejecutable

Campo	Valor observado	Significancia forense
Verified	Unsigned	El ejecutable no posee firma digital válida
Entropy	7.74 / 8.0	La entropía elevada constituye un indicador cuantificable coherente con contenido cifrado o

Campo	Valor observado	Significancia forense
		comprimido; atípica en software legítimo
Company / Product / Description	n/a (todos vacíos)	Ausencia total de metadatos del PE; fuente independiente que confirma el hallazgo de Sysmon ID 1
Link date	10:34 p.m. 4/05/2026	Correlación con timestamp de Sysmon ID 13; confirma integridad de la cadena de evidencia
MD5	726A94B21835A766BB1E5A7D8062676D	Indicador de compromiso (IoC) reproducible
SHA256	634A6640D6F2D122E1BEEFDA6A805B8610DFF5D29C0317547E8325BD76345CA8	Huella forense primaria del payload
IMPHASH	4B58BFA6DB3ED5E731D0D8067899134B	Hash de tabla de importaciones; permite identificar variantes del loader

Hallazgo 5 — ListDLLs: ausencia de módulos no firmados adicionales

La ejecución de ListDLLs con el parámetro -u sobre el PID 4312 identificó únicamente el propio ejecutable loader (5).exe como módulo sin firma digital. No se detectaron DLLs adicionales sin firmar cargadas en el espacio de memoria del proceso.

Campo	Valor	Significancia forense
Módulos sin firma detectados	1 (el propio loader)	Sin módulos maliciosos adicionales en el proceso
Base address	0x00000000eedc0000	Dirección de carga del ejecutable en el espacio virtual

Campo	Valor	Significancia forense
Size en memoria	0x12f9000 (~19.5 MB)	Tamaño en memoria superior al del archivo en disco; indicador compatible con descifrado del payload en memoria
Create time	Mon May 04 22:34:03 2026	Confirma el timestamp de compilación del loader desde una fuente adicional

La ausencia de módulos no firmados adicionales es coherente con técnicas que minimizan la carga de módulos adicionales en memoria: al resolver las llamadas al sistema sin depender de DLLs externas, el implante no genera artefactos de este tipo detectables por ListDLLs.

Hallazgo 6 — VMMap: región ejecutable anónima en memoria

El análisis del mapa de memoria virtual del proceso reveló la presencia de una región ejecutable sin respaldo en ningún módulo del sistema de archivos:

Región	Dirección base	Tamaño	Protección	Significancia
Shareable anónima (bloque total)	0x0000021F9FBC0000	~36 MB (37,044 KB)	Execute/Read	Región ejecutable sin módulo asociado ni ruta en disco; compatible con payload descifrado y activo en memoria
Private Data ejecutable	0x0000021F99C60000	~18 MB (18,448 KB)	Execute/Read	Región de datos privados con permisos de ejecución; anomalía respecto al comportamiento esperado de procesos legítimos
Sección .data del loader (Image)	Dentro del bloque Image	~19 MB (19,428 KB)	Execute/Read	Tamaño atípico para la sección de imagen; compatible con shellcode cifrado dentro del PE

A diferencia de todas las DLLs del sistema presentes en el mapa de memoria (ntdll.dll, kernel32.dll, ws2_32.dll, entre otras), las regiones anónimas identificadas no tienen ruta de origen ni nombre de módulo asociado, constituyendo una anomalía respecto al comportamiento esperado de procesos legítimos.

Hallazgo 7 — Autoruns: ausencia de persistencia registrada

El análisis con Autoruns, utilizando el filtro de búsqueda 'loader', no reveló ninguna entrada de persistencia asociada al loader o al implante en ninguna de las ubicaciones monitoreadas: Logon, Scheduled Tasks, Services, Drivers, WMI, Applnit, Boot Execute e Image Hijacks. El resultado de la búsqueda fue completamente vacío.

La ausencia de persistencia es coherente con el modo de operación del implante analizado: al ejecutarse principalmente en memoria sin escritura adicional en disco, el payload no requiere mecanismos de persistencia convencionales para mantener su actividad durante la sesión activa. Esta característica reduce la superficie de detección en herramientas orientadas a monitorear ubicaciones de arranque del sistema.

La ausencia de persistencia no implica ausencia de compromiso, sino una estrategia operativa orientada a reducir la superficie de detección; característica definitoria de los implantes de tipo fileless.

Línea de Tiempo del Incidente

Timestamp (UTC)	Evento	Fuente	Significancia
15:39:23.805	Creación del proceso loader (5).exe PID 4312 desde explorer.exe	Sysmon ID 1	Inicio del incidente; ejecución manual por el usuario
15:39:24.058	Windows registra el loader en AppCompatFlags	Sysmon ID 13	Telemetría automática del SO; fuente de evidencia independiente
15:39:24.075–25.528	Cinco entradas en InventoryApplicationFile: ruta, publisher (vacío), LinkDate 05/05/2026	Sysmon ID 13	Publisher vacío indica binario no legítimo; LinkDate confirma compilación ~24h antes
~15:39:25	Región ejecutable anónima de ~36 MB aparece en memoria del proceso	VMMMap	Compatible con descifrado y carga del shellcode en memoria
15:39:28.631	Conexión TCP hacia 20.0.0.2:443 (puerto local 50639)	Sysmon ID 3	Canal C2 estableciéndose; DestinationHostname vacío indica IP sin DNS
~12:27 (hora local)	Dos conexiones ESTABLISHED simultáneas hacia 20.0.0.2:443 (puertos 51006 y 51007)	TCPView	Dos canales C2 activos; compatible con modo session o beacon con múltiples conexiones
Continuo	Hilo TID 1916 activo con start address loader (5).exe+0x1440	Process Explorer	Hilo de ejecución activo desde dirección interna del ejecutable; beacon interval activo

Indicadores de Compromiso (IoC)

Tipo	Valor	Fuente de detección
SHA256	634A6640D6F2D122E1BEEFDA6A805B8610DFF5D29C0317547E8325BD76345CA8	Sysmon ID 1 / Sigcheck
MD5	726A94B21835A766BB1E5A7D8062676D	Sysmon ID 1 / Sigcheck
IMPHASH	4B58BFA6DB3ED5E731D0D8067899134B	Sigcheck
IP C2	20.0.0.2	TCPView / Sysmon ID 3
Puerto C2	443/tcp (HTTPS)	TCPView / Sysmon ID 3
Ruta del loader	C:\Users\UNAL CYBEROPS 2\Desktop\loader (5).exe	Sysmon ID 1
Entropía del archivo	7.74 / 8.0	Sigcheck
Región ejecutable anónima	0x0000021F9FBC0000 — ~36 MB — Execute/Read	VMMMap
Fecha de compilación	05/05/2026 04:34:03	Sysmon ID 13 / Sigcheck

6.7 Evidencias

Las siguientes capturas de pantalla respaldan los hallazgos documentados en la sección anterior. Todas las afirmaciones del informe están sustentadas por evidencia verificable obtenida directamente de las herramientas utilizadas durante el análisis.

Evidencia 1 — Process Explorer: pestaña Performance (PID 4312)

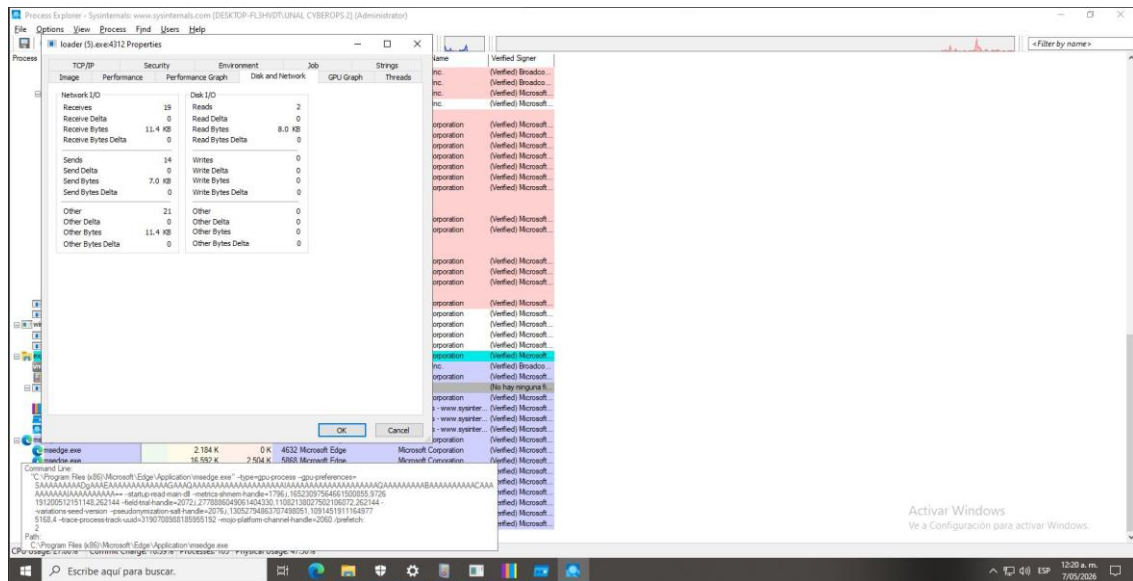


Figura 3. Process Explorer — pestaña Disk and Network. La sección Disk I/O muestra Writes = 0, Write Bytes = 0 y Write Delta = 0, confirmando ausencia de escritura en disco durante el periodo analizado. La sección Network I/O muestra actividad de red activa con bytes recibidos y enviados.

Evidencia 4 — TCPView: conexiones ESTABLISHED hacia 20.0.0.2:443

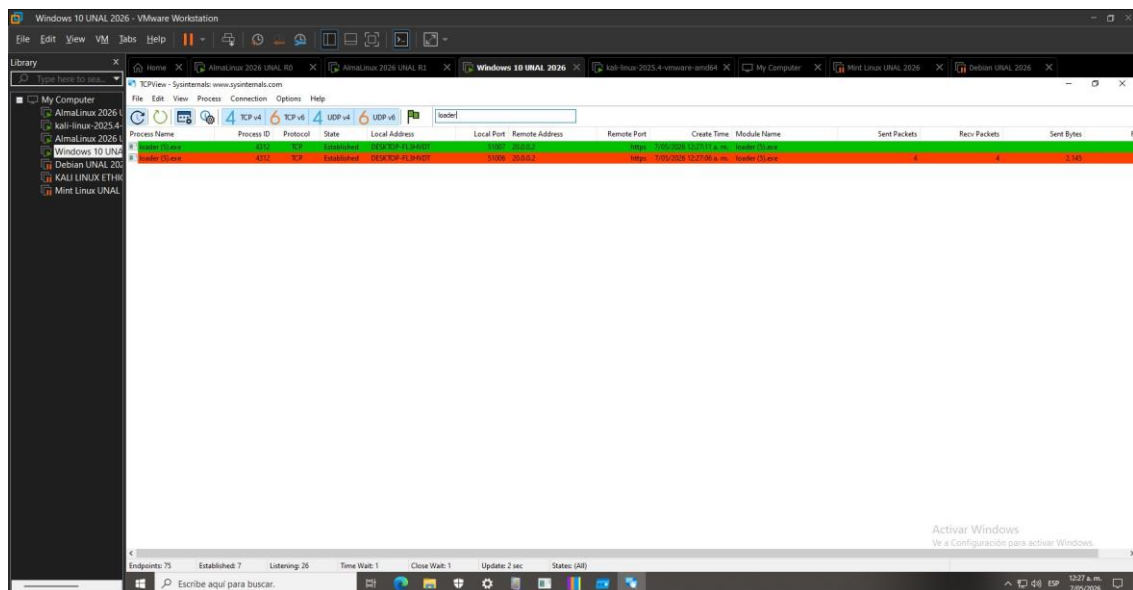


Figura 4. TCPView filtrado por 'loader'. Se observan dos conexiones TCP en estado Established del proceso loader (5).exe (PID 4312) hacia 20.0.0.2 (puerto https/443), con puertos locales 51006 y 51007. La presencia de dos canales simultáneos es compatible con modo session del implante.

Evidencia 5 — Sigcheck: análisis completo del ejecutable

```
Administrator: C:\Windows\system32\cmd.exe
C:\Users\UNAL CYBEROPS 2\Desktop\SysInternalsSuite>sigcheck.exe -accepteula -a -h "C:\Users\UNAL CYBEROPS 2\Desktop\loader (5).exe"

Sigcheck v2.91 - File version and signature viewer
Copyright (C) 2004-2026 Mark Russinovich
Sysinternals - www.sysinternals.com

c:\users\unal cyberops 2\desktop\loader (5).exe:
Verified: Unsigned
Link date: 10:34 p. m. 4/05/2026
Publisher: n/a
Company: n/a
Description: n/a
Product: n/a
Prod version: n/a
File version: n/a
MachineType: 64-bit
Binary Version: n/a
Original Name: n/a
Internal Name: n/a
Copyright: n/a
Comments: n/a
Entropy: 7.74
MD5: 726A94B21B35A766BB1E5A7D8062676D
SHA1: 1684CCA24B127F0408E106044E1479B1DA21E55
PESHA1: E53F4B0D1C36F2316A0A918C4209F0274E0128E
PE256: 01233809F6EFA0FAFE1DAE95A61A66CA54E1E94A62A0AB40D678AF5409EC50
SHA256: 634A6640D6F2D122E18EEFD6A805886180FF5D29C0317547E8325B076345CAB
IMP: 4B58BFA0D03ED5E731D0D0867899134B

C:\Users\UNAL CYBEROPS 2\Desktop\SysInternalsSuite>
```

Figura 5. Sigcheck sobre loader (5).exe. Se confirman: Verified: Unsigned, todos los metadatos del PE vacíos (n/a), Entropy: 7.74, y los hashes MD5, SHA1, SHA256 e IMP del payload. La combinación de ausencia de firma, metadatos vacíos y alta entropía es coherente con un binario malicioso con payload cifrado.

Evidencia 6 — ListDLLs: módulos sin firma en PID 4312

```
Administrator: C:\Windows\system32\cmd.exe
C:\Users\UNAL CYBEROPS 2\Desktop\SysInternalsSuite>sigcheck.exe -accepteula -a -h "C:\Users\UNAL CYBEROPS 2\Desktop\loader (5).exe"

Sigcheck v2.91 - File version and signature viewer
Copyright (C) 2004-2026 Mark Russinovich
Sysinternals - www.sysinternals.com

c:\users\unal cyberops 2\desktop\loader (5).exe:
Verified: Unsigned
Link date: 10:34 p. m. 4/05/2026
Publisher: n/a
Company: n/a
Description: n/a
Product: n/a
Prod version: n/a
File version: n/a
MachineType: 64-bit
Binary Version: n/a
Original Name: n/a
Internal Name: n/a
Copyright: n/a
Comments: n/a
Entropy: 7.74
MD5: 726A94B21B35A766BB1E5A7D8062676D
SHA1: 1684CCA24B127F0408E106044E1479B1DA21E55
PESHA1: E53F4B0D1C36F2316A0A918C4209F0274E0128E
PE256: 01233809F6EFA0FAFE1DAE95A61A66CA54E1E94A62A0AB40D678AF5409EC50
SHA256: 634A6640D6F2D122E18EEFD6A805886180FF5D29C0317547E8325B076345CAB
IMP: 4B58BFA0D03ED5E731D0D0867899134B

C:\Users\UNAL CYBEROPS 2\Desktop\SysInternalsSuite>listdlls.exe -accepteula -u 4312

listdlls v3.2 - listdlls
Copyright (C) 1997-2016 Mark Russinovich
Sysinternals

-----
Command line: "C:\Users\UNAL CYBEROPS 2\Desktop\loader (5).exe"

Base      Size      Path
0x00000000 0x12f9000 C:\Users\UNAL CYBEROPS 2\Desktop\loader (5).exe
Verified: Unsigned
Publisher: n/a
Description: n/a
Product: n/a
Version: n/a
File version: n/a
Create time: Mon May 04 22:34:03 2026

C:\Users\UNAL CYBEROPS 2\Desktop\SysInternalsSuite>
```

Figura 6. Output combinado de Sigcheck y ListDLLs -u en la misma sesión de cmd. ListDLLs identifica únicamente el loader (5).exe (base 0x00000000eedc0000, size 0x12f9000) como módulo sin firma. Create time: Mon May 04 22:34:03 2026, correlacionando el timestamp con Sysmon y Sigcheck.

Evidencia 7 — Autoruns: búsqueda de 'loader' sin resultados

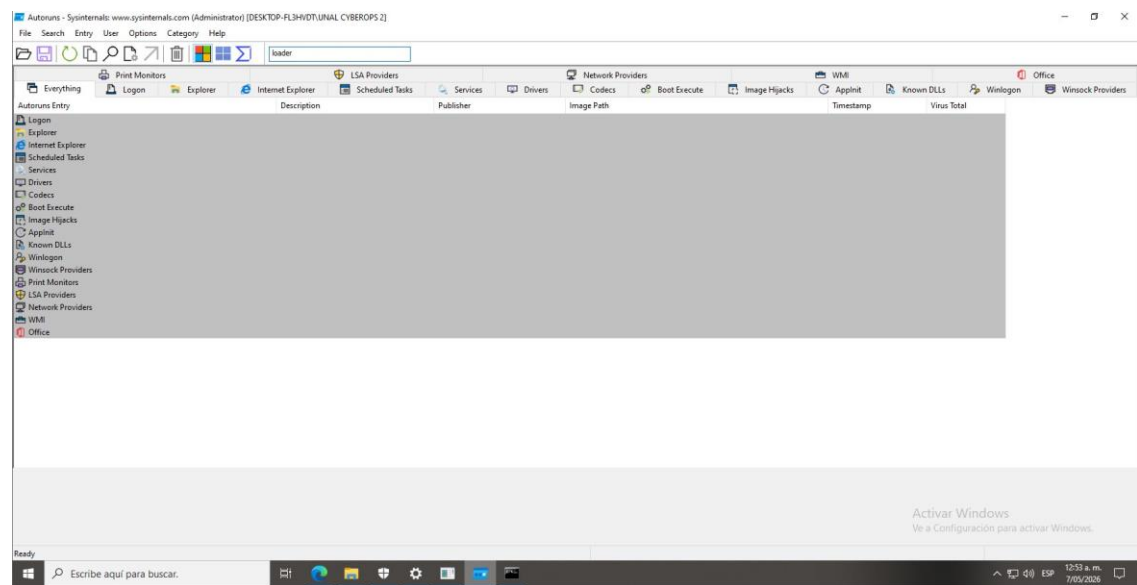


Figura 7. Autoruns con búsqueda activa del término 'loader'. El resultado es completamente vacío en todas las categorías: Logon, Explorer, Internet Explorer, Scheduled Tasks, Services, Drivers, Codecs, Boot Execute, Image Hijacks, AppInit, Known DLLs, Winlogon, Winsock Providers, Print Monitors, LSA Providers, Network Providers, WMI y Office. No existe ninguna entrada de persistencia asociada al implante.

Evidencia 8 — Sysmon Event ID 1: creación del proceso

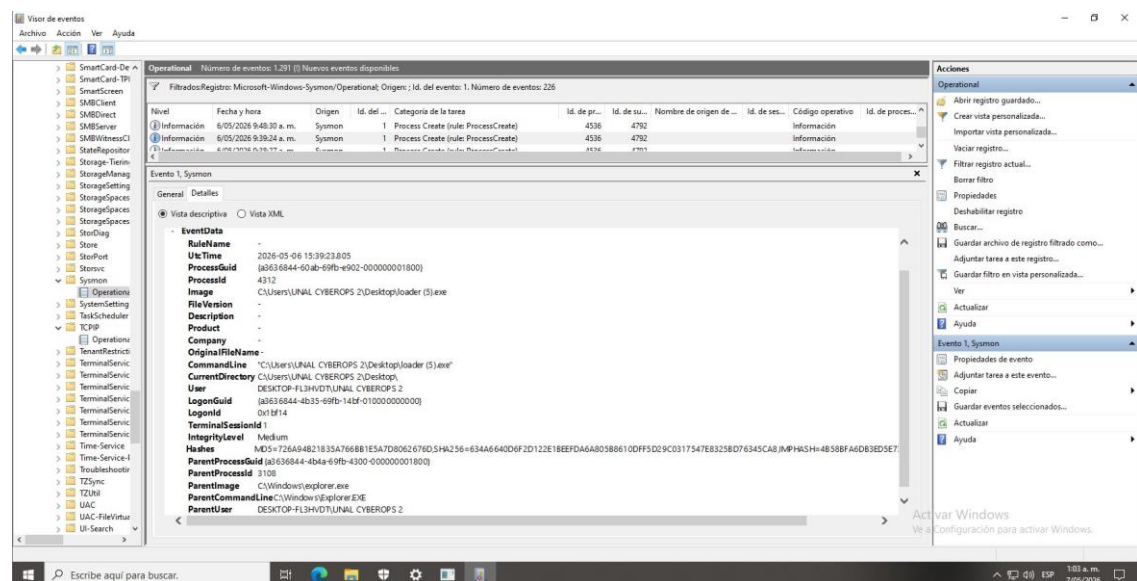


Figura 8. Sysmon Event ID 1 — Process Create. Se observan los campos FileVersion, Description, Product y Company vacíos ('-'), OriginalFileName vacío, los hashes MD5, SHA256 e IMPHASH del payload, IntegrityLevel: Medium, ParentImage: C:\Windows\explorer.exe y ParentUser: DESKTOP-FL3HVD\UNAL CYBEROPS 2.

Evidencia 9 — Sysmon Event ID 13: registro del loader con Publisher vacío

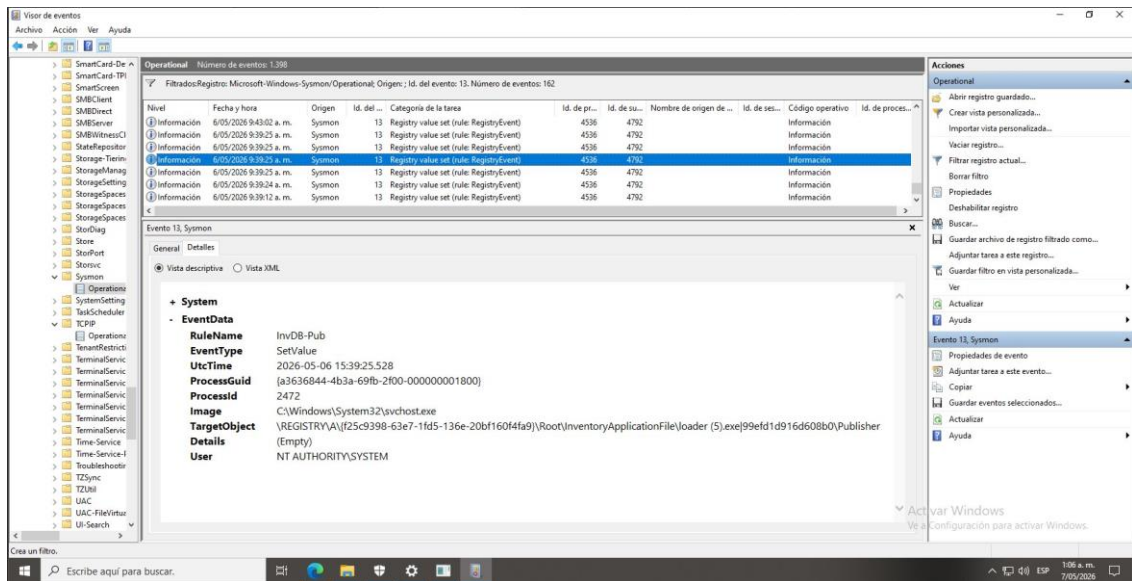


Figura 9. Sysmon Event ID 13 — Registry value set. El campo TargetObject apunta a InventoryApplicationFile\loader (5).exe...\Publisher y el campo Details muestra (Empty). Generado por svchost.exe (PID 2472) a las 15:39:25 UTC. El Publisher vacío corrobora la ausencia de firma digital desde una fuente de telemetría independiente.

Evidencia 10 — Sysmon Event ID 3: conexión de red al C2

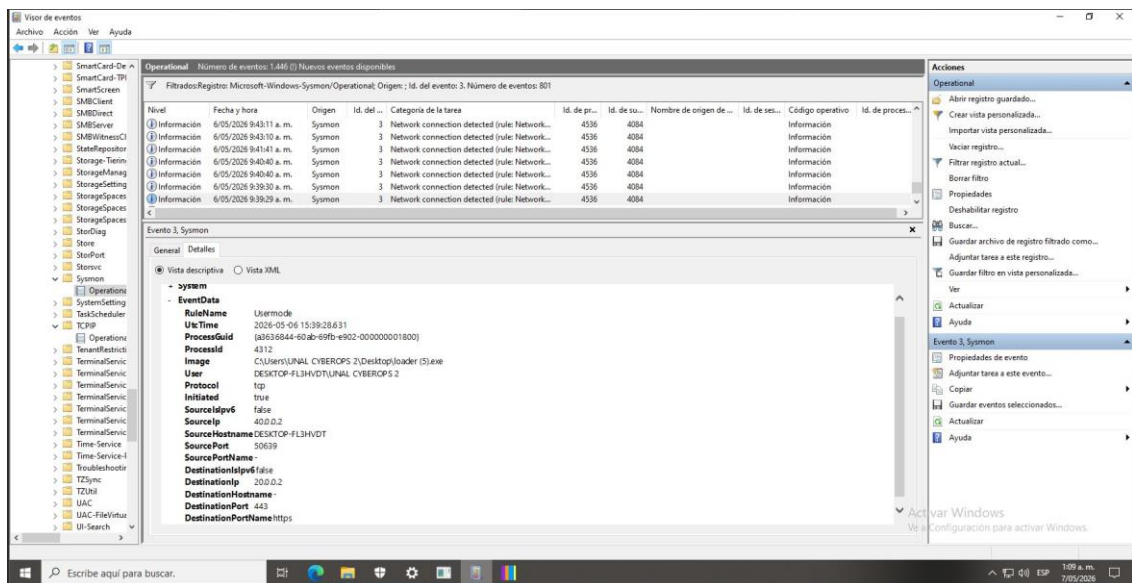


Figura 10. Sysmon Event ID 3 — Network connection detected. Se observan múltiples eventos ID 3 en el listado superior. El evento detallado muestra: Image: C:\Users\UNAL CYBEROPS 2\Desktop\loader (5).exe, ProcessId: 4312, SourceIp: 40.0.0.2, SourcePort: 50639, DestinationIp: 20.0.0.2, DestinationPort: 443, DestinationHostname: - (vacío). UtcTime: 2026-05-06 15:39:28.631.

Evidencia 11 — VMMap: región Shareable Execute/Read anónima

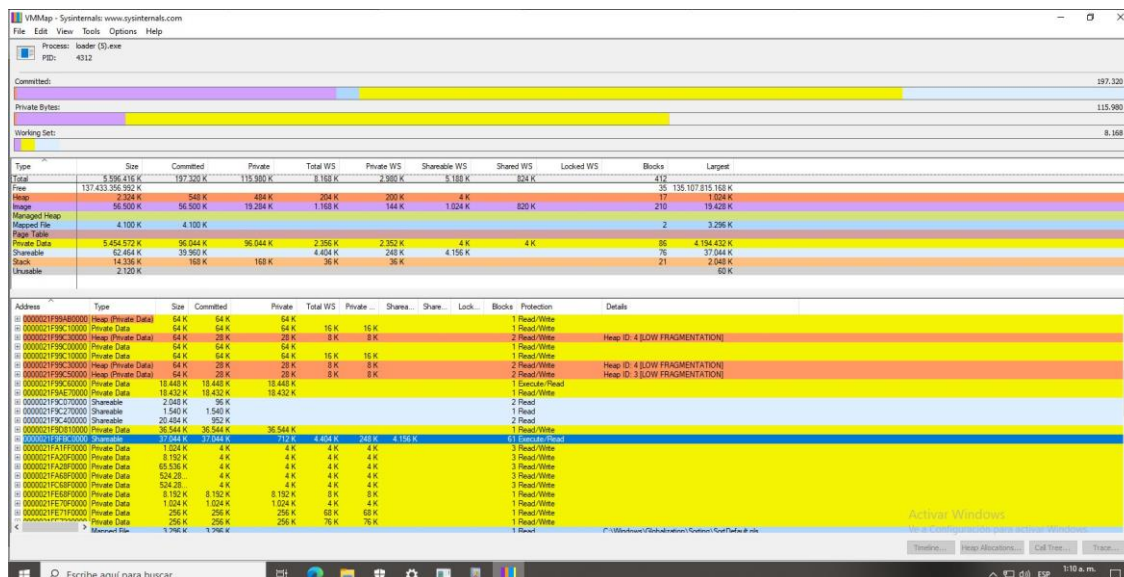


Figura 11. VMMap del proceso loader (5).exe (PID 4312). En la tabla inferior se observa la región resaltada en azul: dirección 0x0000021F9FBC0000, tipo Shareable, tamaño 37,044 KB (~36 MB), protección Execute/Read, sin nombre de módulo en la columna Details. En el resumen superior se confirma Private Data de 5,454,572 KB y Shareable con 62,464 KB. La ausencia de ruta asociada a esta región ejecutable es compatible con payload activo en memoria.

6.8 Análisis e Interpretación

Argumento central

El loader implementa técnicas de evasión a nivel de instrucción; sin embargo, no logra ocultar los efectos observables de su ejecución a nivel de sistema. Esta discrepancia constituye el hallazgo conceptual más relevante del análisis.

Técnicas de evasión identificadas y su alcance

Técnica	Mecanismo	Qué busca evadir
Indirect syscalls (indicadores compatibles)	El comportamiento observado sugiere el cálculo dinámico del número de syscall desde ntdll.dll, realizando la llamada directamente al kernel.	Evade la instrumentación en espacio de usuario, limitando la visibilidad de mecanismos de monitoreo con hooks en ntdll.dll.
Ejecución en memoria	El payload principal se ejecuta en memoria RAM sin escritura adicional en disco durante el periodo analizado.	Reduce la superficie de detección por herramientas basadas en análisis de archivos en disco.
Puerto 443 (HTTPS)	El beacon utiliza el puerto estándar HTTPS como transporte.	Dificulta la diferenciación frente a tráfico HTTPS legítimo en inspecciones superficiales de red.
Memoria Shareable (no Private)	La región ejecutable se asigna como Shareable en lugar de Private Data.	El uso de un tipo de memoria menos común puede evadir heurísticas basadas en patrones típicos de asignación utilizados por algunos scanners.

Técnica	Mecanismo	Qué busca evadir
Metadatos PE vacíos	El ejecutable no contiene Company, Description, Product ni OriginalFileName.	Dificulta la clasificación automática por herramientas que utilizan metadatos del PE como criterio de confianza.

Visibilidad residual: indicadores que el loader no logra suprimir

Indicador observable	Herramienta	Por qué permanece visible
Entropía 7.74 / 8.0	Sigcheck	La entropía elevada constituye un indicador cuantificable coherente con contenido cifrado o comprimido; característica atípica en ejecutables legítimos.
Kernel Time superior al User Time	Process Explorer	La actividad en espacio del kernel es registrada por el sistema operativo independientemente del mecanismo de llamada utilizado.
Región Shareable ejecutable anónima (~36 MB)	VMMMap	La ejecución en memoria implica necesariamente la asignación de espacio virtual, observable mediante análisis del mapa de memoria del proceso.
Hilo TID 1916 con start address interno	Process Explorer	Un hilo iniciado desde una dirección interna sin función exportada es compatible con ejecución de código cargado en memoria; característica estructural observable.
Dos conexiones TCP simultáneas a C2	TCPView / Sysmon ID 3	La comunicación con el servidor C2 es inherente al funcionamiento del implante; genera actividad de red observable independientemente del protocolo utilizado.
Process Create con metadatos vacíos	Sysmon ID 1	Windows registra toda creación de proceso; los metadatos vacíos quedan reflejados en el registro del evento.
DestinationHostname vacío en conexiones C2	Sysmon ID 3	La ausencia de nombre de dominio resoluble en el destino de las conexiones es un indicador compatible con comunicación directa a IP de C2 sin infraestructura DNS.

La paradoja de la evasión

El loader analizado implementa un conjunto de técnicas de evasión técnicamente sofisticadas. Los indicadores analizados sugieren el uso de indirect syscalls como mecanismo de evasión: al calcular dinámicamente los números de syscall sin invocar las funciones expuestas por ntdll.dll, el implante limita la visibilidad ofrecida por las herramientas utilizadas durante el análisis en la capa de espacio de usuario. La ejecución en memoria reduce la superficie de detección de herramientas basadas en análisis de archivos en disco.

Sin embargo, esta sofisticación contrasta con la considerable cantidad de telemetría observable generada durante su ejecución. El implante presenta indicadores detectables en múltiples dimensiones: la entropía elevada del ejecutable es un indicador cuantificable coherente con contenido cifrado; la desproporción entre Kernel Time y User Time indica actividad inusual en la capa del sistema; la región ejecutable anónima de ~36 MB no tiene correspondencia con ningún módulo legítimo; y la presencia de dos conexiones TCP

simultáneas hacia la misma IP en puerto 443 genera una firma de red característica detectable mediante correlación de eventos.

Esta discrepancia evidencia un principio fundamental del análisis forense digital: la detección no depende exclusivamente de identificar el mecanismo técnico de evasión, sino de correlacionar los efectos comportamentales que dicho mecanismo inevitablemente produce. Un implante puede limitar la visibilidad a nivel de instrucción sin poder ocultar los efectos observables de sus acciones a nivel de sistema.

Brecha de visibilidad de las herramientas utilizadas

Las herramientas utilizadas durante el análisis no proporcionan visibilidad directa sobre las llamadas al kernel realizadas mediante indirect syscalls. Sysinternals opera principalmente en dos capas: las herramientas de espacio de usuario instrumentan la API de Windows, y Sysmon opera como driver del kernel registrando eventos de alto nivel. Las indirect syscalls ocurren en la transición userland→kernel a nivel de instrucción, limitando la visibilidad ofrecida por dichas herramientas en esa capa específica.

Sin embargo, Sysmon captura los efectos de esas llamadas: la creación del proceso, las conexiones de red y las modificaciones de registro son efectos observables independientemente del mecanismo de llamada utilizado. VMMap permite observar la región ejecutable anónima resultante de la asignación de memoria. La detección de indirect syscalls como técnica específica requeriría herramientas complementarias con capacidad de análisis de memoria en tiempo real, como PE-sieve o soluciones EDR con kernel callbacks dedicados.

Mapeo MITRE ATT&CK

Táctica	Técnica	ID	Evidencia en el análisis
Execution	Native API	T1106	Indicadores compatibles con indirect syscalls; Kernel Time superior al User Time en Process Explorer
Defense Evasion	Reflective Code Loading	T1620	Sin escritura adicional en disco durante el periodo analizado; región ejecutable anónima de ~36 MB en VMMap
Defense Evasion	Obfuscated Files or Information	T1027	Entropía 7.74/8.0; tamaño en memoria del loader (~19.5 MB) superior al del archivo en disco
Defense Evasion	Masquerading	T1036	Metadatos PE completamente vacíos; ausencia de firma digital verificada
Command & Control	Application Layer Protocol: Web	T1071.001	Dos conexiones HTTPS simultáneas puerto 443 hacia 20.0.0.2; uso de protocolo web como transporte C2
Command & Control	Encrypted Channel	T1573	Tráfico cifrado hacia el C2; DestinationHostname vacío en Sysmon ID 3

El conjunto de técnicas identificadas es compatible con el comportamiento de implantes fileless modernos utilizados en operaciones de comando y control.

6.9 Conclusiones

El análisis forense realizado sobre el sistema comprometido permitió identificar, documentar y correlacionar un conjunto de evidencias técnicas que caracterizan el comportamiento de un implante generado mediante el framework Sliver, desplegado a través de un loader cuyo comportamiento observado es compatible con el uso de indirect syscalls y carga reflectiva en memoria.

La correlación de múltiples fuentes de evidencia independientes permitió reconstruir la secuencia de ejecución del implante, identificar indicadores de compromiso y caracterizar su comportamiento, sin requerir acceso al código fuente ni técnicas avanzadas de ingeniería inversa. Los hashes criptográficos obtenidos (SHA256: 634A6640..., MD5: 726A94B2...) constituyen indicadores de compromiso reproducibles y verificables, integrables en plataformas de inteligencia de amenazas.

Se documentó que el payload principal fue ejecutado en memoria sin evidencia de escritura adicional en disco durante el periodo analizado, y sin mecanismos de persistencia activos en las ubicaciones monitoreadas por Autoruns. Esta combinación constituye un patrón comportamental consistente con la naturaleza del implante analizado: la presencia de regiones ejecutables anónimas en memoria junto con dos conexiones TCP activas hacia el C2 y cero escrituras en disco proporciona evidencia suficiente para inferir la naturaleza del incidente.

La detección basada en la correlación de efectos comportamentales constituye un mecanismo complementario eficaz frente a técnicas de evasión de bajo nivel: un implante puede limitar la visibilidad a nivel de instrucción sin poder ocultar los efectos observables de sus acciones a nivel de sistema. Este principio es un fundamento del análisis forense digital y fue evidenciado de forma práctica en el presente ejercicio.

Adicionalmente, la ausencia de persistencia no implica ausencia de compromiso, sino una estrategia operativa orientada a reducir la superficie de detección; característica definitoria de los implantes de tipo fileless.

El análisis fue realizado sobre un sistema en ejecución dentro de un entorno de laboratorio controlado, por lo que los hallazgos corresponden al comportamiento observable durante el periodo analizado y no necesariamente representan la totalidad de las capacidades del implante.

6.10 Recomendaciones

Con base en los hallazgos del análisis, se propone una estrategia de detección en capas orientada a mitigar o detectar incidentes de características similares:

Capa 1 — Detección estática en punto de entrada

- Se recomienda implementar reglas de alerta para ejecutables con entropía superior a 7.0 ejecutados desde directorios de usuario (Desktop, Downloads, AppData). La entropía de 7.74 observada en el loader representa un indicador temprano de payload cifrado detectable antes de la ejecución.
- Se sugiere restringir la ejecución de binarios sin firma digital válida mediante políticas de control de aplicaciones (AppLocker o Windows Defender Application Control), dado que la ausencia de firma fue confirmada por tres fuentes independientes.
- Se recomienda alertar sobre ejecutables cuyos metadatos PE (Company, Description, Product) se encuentren completamente vacíos, condición atípica en software legítimo e identificada como indicador consistente en el presente análisis.

Capa 2 — Detección comportamental en ejecución

- Se recomienda configurar alertas cuando el Kernel Time de un proceso supere significativamente su User Time durante periodos sostenidos, condición observada en el proceso analizado y compatible con técnicas de llamada directa al kernel.
- Se sugiere implementar alertas para procesos que mantengan múltiples conexiones TCP simultáneas hacia el mismo destino en puerto 443, patrón observado en el comportamiento del implante analizado.
- Se recomienda alertar sobre conexiones HTTPS cuyo campo DestinationHostname se encuentre vacío en los registros de Sysmon ID 3, indicador de conexión hacia IPs sin resolución DNS válida identificado durante el análisis.

Capa 3 — Detección en memoria

- Se recomienda implementar escaneos periódicos con herramientas especializadas como PE-sieve para identificar regiones ejecutables anónimas de tamaño significativo en procesos de usuario, condición no detectable directamente mediante las herramientas utilizadas en el presente análisis.
- Se sugiere monitorear regiones de tipo Shareable con permisos Execute/Read sin módulo asociado en el espacio de direcciones de procesos activos, anomalía identificada mediante VMMap y compatible con carga reflectiva de código.

Capa 4 — Detección de red

- Se recomienda orientar la inspección de tráfico hacia conexiones HTTPS que se dirijan hacia IPs privadas o sin nombre de dominio resoluble, técnica empleada por el implante analizado para dificultar la inspección superficial.
- Se sugiere integrar los indicadores de compromiso identificados (SHA256: 634A6640..., IP: 20.0.0.2) en las plataformas de monitoreo de red y SIEM del entorno como punto de partida para la detección de variantes del mismo implante.
- Se recomienda correlacionar eventos Sysmon ID 3 con listas de reputación de IPs, alertando sobre destinos no clasificados como legítimos en el contexto de la organización analizada.